LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet. 1) Bileşen var: Component X, SBOM'a göre PLC firmware'inde. 2) Sürüm etkileniyor: v2.4 etkilenen aralıkta. 3) Ulaşılabilir: yalnızca OT ağı içinden (Z2/Z3); internete doğrudan açık değil.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır. Açık sadece iç ağdan istismar edilebilir ve emniyet fonksiyonu Safety PLC'de bağımsızdır. Önce telafi edici önlemler alınır, yama planlı duruşta uygulanır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test. Yama yedek/test PLC'de veya üreticinin test ortamında denenir; mevcut program yedeklenir ve geri dönüş planı hazırlanır, sonra planlı duruşta uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Firmware değişikliği safety fonksiyonlarını etkileyebilir. Üreticinin sürüm notu ve safety sertifika durumu incelenir; Safety PLC veya safety I/O etkileniyorsa E-stop, kapı kilidi, ışık perdesi yeniden doğrulanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Ağ bölütleme ve firewall ile PLC'ye erişim yalnızca mühendislik istasyonuna sınırlanır; ilgili port/servis kapatılır; uzak erişim varsayılan kapalı tutulur; IDS/ağ izleme ile anormal trafik takip edilir. Durum Risk Register'a işlenir ve yama için tarih planlanır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.